PAPER FOR THE BOARD RISK COMMITTEE

CRO Risk Report

November 2026

Presented by	Reporting period	Position as at	Classification
Chief Risk Officer (SMF4)	**November 2026**	**5 Nov 2026**	**Confidential**

Executive summary

Firm posture	Out of tolerance	Critical controls	Incidents
RED	**2 metrics**	**94%**	**1 Sev-1 · 2 Sev-2**
Same as Oct · Cyber & Information Security	Worst: Critical vulnerabilities open	Down from 96%	Exploit attempt on unpatched perimeter vulnerability

Key messages

- Firm risk posture is RED, unchanged from Oct, driven by Cyber & Information Security. [RAM-CY-01]
- 2 risk appetite metrics are out of tolerance: Critical vulnerabilities open (3 open vs tolerance 2 open); Mean time to patch critical vulnerabilities (432 hours vs tolerance 336 hours). [RAM-CY-01, RAM-CY-02]
- Critical controls are 94% effective, down from 96%; the lowest is Fraud & Financial Crime at 85%. [AML-C002]
- AML-C002 retested 3 Nov 2026: not effective. Disposition control under capacity stress. [AML-C002]
- 1 Sev-1 incident and 2 Sev-2 incidents are open or new this month, led by: Exploit attempt on unpatched perimeter vulnerability. [INC-2026-041, INC-2026-040]
- On the horizon: Google Cloud London region outage disrupts banks (Reuters, 21 Oct 2026). [HZ-IND-001]

Matters for the Committee

- Note: KYC refresh backlog on high-risk relationships is past its 31 Oct 2026 target. Delay accepted by Board Risk Committee, 12 Oct 2026.
- Review: the plan for Mean time to patch critical vulnerabilities was sent back on 12 Oct 2026.
- Decide: the path to green for Exploit attempt on unpatched perimeter vulnerability, target 30 Nov 2026.
- Decide: the path to green for AML Alert Disposition SLA Control, target 29 Jan 2027.

1. Risk profile

Firm risk posture is **RED** (also RED in Oct). Any Level-1 risk red makes the firm red; driven by Cyber & Information Security.

Level-1 risk	Rating	Since last review	RAMs red / amber	Critical controls	Sev-1/2	Basis of rating
Cyber & Information Security	RED	Unchanged	2 / 1	90%	2	Red because 2 RAMs out of tolerance · 1 critical control failed · 1 Sev-1 incident Path to green: Jan 2027 · Head of Information Security
Fraud & Financial Crime	AMBER	Unchanged	0 / 5	85%	1	Amber because 5 RAMs above limit · critical controls 85% effective · 1 Sev-2 incident Path to green: Apr 2027 · Head of Financial Crime Compliance
Climate Risk	GREEN	Unchanged	0 / 0	100%	0	Within appetite · critical controls 100% effective
Conduct & Reputation	GREEN	Unchanged	0 / 0	100%	0	Within appetite · critical controls 100% effective
Credit Risk	GREEN	Improved	0 / 0	100%	0	Within appetite · critical controls 100% effective
Liquidity & Funding	GREEN	Unchanged	0 / 0	100%	0	Within appetite · critical controls 100% effective
Market Risk	GREEN	Unchanged	0 / 0	100%	0	Within appetite · critical controls 100% effective
Operational Resilience	GREEN	Unchanged	0 / 0	100%	0	Within appetite · critical controls 100% effective
Regulatory	GREEN	Unchanged	0 / 0	100%	0	Within appetite · critical controls 100% effective

Assurance: 1 green domain has no test evidence this cycle. **Rating rule:** Red if any metric is red, critical-control effectiveness is below 85% or a Sev-1 incident is open. Amber if any metric is amber, effectiveness is below 95% or a Sev-2 incident is open. Otherwise green.

2. Risk appetite

Of 50 risk appetite metrics, 42 are green, 6 amber and 2 red. Red and amber metrics are set out below.

Metric	Value	Limit	Tolerance	Cause	Path to green	Second line and committee
Critical vulnerabilities open RED Cyber & Information Security	**3 open**	0	2	Vendor patch for the perimeter security stack needs phased rollout across production.	13 Nov 2026	Accepted Accepted by Board Risk Committee, 12 Oct 2026
Mean time to patch critical vulnerabilities RED Cyber & Information Security	**432 hours**	168	336	Patch windows are shared with core-banking release freezes.	29 Jan 2027	Challenged Sent back by Board Risk Committee, 12 Oct 2026
Privileged access reviews overdue AMBER Cyber & Information Security	**2 reviews**	0	5	Two quarterly reviews slipped during the vulnerability response.	30 Nov 2026	Pending Decision pending at Executive Risk Committee
AML alert backlog above SLA AMBER Fraud & Financial Crime	**6.4%**	5%	8%	Alert volumes exceed L2 investigator capacity.	26 Feb 2027	Accepted Bring forward, decided by Executive Risk Committee, 20 Oct 2026
EDD completed on time AMBER Fraud & Financial Crime	**93%**	98%	90%	EDD analysts were redeployed to the KYC refresh backlog.	29 Jan 2027	Accepted Accepted by Executive Risk Committee, 20 Oct 2026
High-risk reviews overdue AMBER Fraud & Financial Crime	**17%**	5%	20%	Linked to the KYC refresh backlog on high-risk relationships.	30 Apr 2027	Accepted Accepted by Board Risk Committee, 12 Oct 2026
KYC refresh backlog on high-risk relationships AMBER Fraud & Financial Crime	**4,380 cases**	1,000	5,000	Periodic refreshes were deferred during the core-banking migration.	31 Oct 2026 (overdue)	Accepted Delay accepted by Board Risk Committee, 12 Oct 2026
TM alerts closed within SLA AMBER Fraud & Financial Crime	**86%**	95%	80%	L1 and L2 queues are running above planned capacity.	26 Feb 2027	Accepted Accepted by Executive Risk Committee, 20 Oct 2026

3. Controls and incidents

94% of critical controls are effective, against 96% in the previous period.

Level-1 risk	This period	Previous	Critical controls effective
Fraud & Financial Crime	85%	90%	
Cyber & Information Security	90%	90%	
Climate Risk	100%	100%	
Conduct & Reputation	100%	100%	
Credit Risk	100%	100%	
Liquidity & Funding	100%	100%	
Market Risk	100%	100%	
Operational Resilience	100%	100%	
Regulatory	100%	100%	

Month-on-month movement

- AML-C002 retested 3 Nov 2026: not effective. Disposition control under capacity stress.

Sev-1 and Sev-2 incidents

Date	Severity	Incident	Category	Status	Linked controls
4 Nov 2026	**Sev-1**	Exploit attempt on unpatched perimeter vulnerability	Cyber & Information Security	Open	CY-C001: failed, CY-C006: worked
4 Nov 2026	**Sev-2**	Cross-border structuring alerts past disposition SLA	Fraud & Financial Crime	Open	AML-C002: failed
22 Oct 2026	**Sev-2**	Privileged account activity outside approved change window	Cyber & Information Security	Open	CY-C004: partial

4. Horizon scanning

Regulatory

Item	Source	Date	Why it matters
Barclays Bank PLC	FCA	14 Jul 2025	479 days not assessed. Reviewed exposure only after a peer was prosecuted
Nationwide Building Society	FCA	11 Dec 2025	329 days not assessed. "Enhanced" CDD reached 4.9% of the book

Industry events

Item	Source	Date	Why it matters
Google Cloud London region outage disrupts banks	Reuters, 21 Oct 2026	20 Oct 2026	A power event at a third-party facility took europe-west2 down for several hours; Revolut, Lloyds and HSBC were reported affected, and the EBA and FCA engaged Google.
Lloyds Banking Group app defect exposes transaction data	The Register, 27 Mar 2026	12 Mar 2026	An overnight IT change let up to 447,936 Lloyds, Halifax and Bank of Scotland customers see other customers' transaction lists; the Treasury Committee sought answers.

Emerging risks

Item	Source	Date	Why it matters
Post-quantum cryptography migration	NCSC, Mar 2025	20 Mar 2025	NCSC milestones: discovery and a migration plan by 2028, priority migration by 2031, full migration by 2035.
AI deepfake impersonation in investment scams	Cyber Daily, 10 Jun 2026	10 Jun 2026	The Bank of England warned that fake adverts impersonating central banks are on the rise, including AI deepfakes of its Governor.

Ratings in this paper are calculated by rule from risk appetite metrics, control test results and incidents. Identifiers in square brackets refer to the underlying records.